

智能体驱动的 AI 安全知 识情报系统设计与实现

知盾 ZhìDùn：多源监测 · 证据富化 · 可追溯问答的 AI 安全情报闭环

参赛赛题：赛题九 · 网信产业应用赛道

命题单位：奇安信科技集团股份有限公司

团队名称：【填写团队名称】

版本日期：2026 年 9 月 29 日

重要内容预览：核心亮点

知盾（ZhiDùn）是一套面向 AI 安全领域的情报系统原型：以可审计的多 Agent 工作流，把分散在 CVE/NVD、GitHub Advisory、CISA KEV、厂商公告、CERT、安全社区、研究博客等渠道的 AI 安全信息，汇聚为带出处的知识库，并在其上提供证据式自然语言问答。以下为核心亮点速览，正文含完整设计、实现与测试证据。

- **多源监测** 当前配置 12 个在线源条目：9 个漏洞监测候选源、3 个论文/标准/政策知识源。增量游标、原样重放幂等、失败重试与状态记录可运行；“7 类实时”评分档位尚未验证。
- **来源字段与规则富化** 产品、受影响版本、修复版本、CVSS、参考链接等从来源记录写入带文档外键的声明；本地虚构资产按版本规则匹配。离线样例没有 PoC 链接，字段数量不等于已验证的五维深度富化。
- **可解释规则关联** 同 CVE 双来源归并、文档显式提及、同产品弱关联三种规则路径分别保留理由；Ollama 公告与 Wiz 分析作为同一 CVE 的两份材料，不能据此宣称通用跨文档多跳推理。
- **带引用的规则问答** CVE/产品定位结合 FTS5 检索，答案显示 [n] 来源和 trace；支持一条指代式追问及证据不足时拒答。9 道开发规则题通过不代表问答语义准确率。
- **可审计多 Agent 编排** 采集、分诊、归一、富化、关联、问答与重试等步骤以角色名记录事件；当前是确定性可审计编排。可选 GLM-5.3 做意图规划与本地已证据化公开段落的选择，失败回退本地。
- **全流程自动化与工程化** Python 标准库和 SQLite/FTS5 支撑离线全链路；提供 HTTP API、事件日志、指标与 Docker/Compose、CI 配置。容器、CI 和长期在线稳定性须分别保留真实运行证据。

- **指标诚实可复核** 9 道预先选定的离线开发题通过预设词、实体、来源 URL、事实同行引用标记及轨迹检查；这是规则通过率，不是语义准确率或官方 95% 指标。进程内耗时随机器和运行次数变化。
- **安全合规边界** 只登记授权资产，不扫描陌生目标；离线样例没有 PoC，在线候选链接只存元数据且不执行。GLM 可接收用户问题和候选公开情报段落，但不会接收资产段落或数据库全文。
- **Agent 自安全自检** 对照 OWASP Agentic AI 建议自定六个攻击面案例并在本地临时库测试；6/6 仅为当前开发样例结果，不是 OWASP 认证或全面安全保证。

(正文目录见下页；各章含完整设计图、数据表与实测结果。)

目 录

- 1 赛题理解与需求分析..... 1
 - 1.1 赛题背景与核心诉求..... 1
 - 1.2 评价维度与本项目响应..... 1
 - 1.3 设计原则..... 3
- 2 系统总体架构设计..... 4
 - 2.1 架构总览..... 4
 - 2.2 关键技术选型说明..... 5
 - 2.3 数据流水线与部署形态..... 6
- 3 智能体方案设计..... 7
 - 3.1 角色划分与职责契约..... 7
 - 3.2 任务编排与自主决策..... 8
 - 3.3 安全边界：不可信输入与注入防护..... 9
- 4 情报监测模块设计..... 10
 - 4.1 数据源覆盖..... 10
 - 4.2 连接器抽象与增量机制..... 11
 - 4.3 去重与归一..... 12
 - 4.4 时效性度量..... 12
- 5 情报富化模块设计..... 13
 - 5.1 证据化声明模型..... 13
 - 5.2 字段抽取与规则扩展..... 13
 - 5.3 自动关联推理..... 14
 - 5.4 资产影响评估..... 14
 - 5.5 冲突与不确定性处理..... 15
- 6 情报问答模块设计..... 16
 - 6.1 问答执行流程..... 16
 - 6.2 规则关系路径与适用边界..... 16
 - 6.3 多轮对话与拒答..... 17
 - 6.4 可选 GLM-5.3 的作用与数据边界..... 17

6.5 真实输出示例.....	18
7 系统实现细节.....	19
7.1 代码结构.....	19
7.2 数据库模式.....	20
7.3 HTTP API.....	20
7.4 前端控制台.....	21
7.5 部署与工程化.....	22
8 核心代码说明.....	23
8.1 证据化声明抽取 (app/intelligence.py)	23
8.2 保守版本匹配 (app/intelligence.py)	23
8.3 问答编排与拒答 (app/qa.py)	24
9 功能实现效果展示.....	25
9.1 演示数据与场景说明.....	25
9.2 关键能力演示路径.....	25
9.3 Agent 轨迹示例.....	26
10 性能测试结果与分析.....	27
10.1 评测方法与口径.....	27
10.2 测试结果.....	27
10.3 局限与误差分析.....	28
11 创新点总结.....	29
12 限制与后续工作.....	30

1 赛题理解与需求分析

1.1 赛题背景与核心诉求

随着大语言模型与智能体技术的爆发式应用，AI 安全漏洞信息分散在 CVE/NVD、安全社区、厂商公告、学术论文、技术博客等多个渠道，安全从业者面临严重的信息过载：难以快速获取、消化并关联关键情报。现有安全情报系统多依赖人工采集与规则匹配，既缺乏对 AI 安全这一新兴领域的深度覆盖，也缺少基于自然语言的智能问答能力。

赛题要求基于智能体技术设计并实现自动化的 AI 安全知识情报系统，具备三大核心能力：情报监测（多源自动化采集与汇聚）、情报富化（论文关联、受影响资产、POC、CVSS 评分等多维扩展）、情报问答（复杂查询理解、跨文档语义检索与关联推理）；并同步采集论文、标准与政策构建知识底座。赛题明确鼓励智能体在任务编排、自主决策、工具调用方面的发挥，同时以功能完整性、性能与工程能力、文档与演示效果综合评价。

我们对赛题的本质判断是：这不是一个漏洞列表工具或通用聊天机器人，而是一条“持续发现 → 可信富化 → 可追溯问答”的情报闭环。AI 安全世界里谣言、误报与夸大并不少见，因此系统的差异化价值在于每条结论可回溯到原始出处、每步推理可检查、证据不足时诚实拒答。这一判断直接决定了后文的架构与算法取舍。

1.2 评价维度与本项目响应

下表将初赛评分表的主要条目映射到本项目的具体设计响应，正文各章逐一展开。

表 1-1 初赛评价指标与本项目的响应映射

评价项（分值）	档位要求	本项目响应
情报监测完整性（15）	≥7 类数据源且含实时监测为优秀	12 个在线配置中有 9 个监测候选源、3 个知识源；一次开发运行不证明“7 类且实时”，需逐类持续取证（第 4 章）
情报富化完整性（15）	≥5 维且准确、含自动关联推理为优秀	来源字段声明、同 CVE/提及/产品规则关联及虚构资产版本匹配已实现；5 维深度富化与准确率待独立评测（第 5 章）
情报问答完整性（15）	跨文档推理与深度分析为优秀	CVE/产品检索、同 CVE 双源归并、有限会话追问与拒答已演示；语义多跳能力未达可证明档位（第 6 章）
监测时效性（5）	≤6 小时为优秀	双时间戳、模式标记与统计代码已具备；离线摘要大多只有日期，无法证明 ≤6 小时
富化准确率（5）	≥95% 为优秀	来源字段抽取与规则匹配有开发断言；尚无独立人工真值集或富化准确率估计
问答准确率（5）	多跳推理准确率 ≥85% 为优秀	9 道开发题预设规则通过 9/9，三道双源/关联题均围绕同一 CVE；不能作为问答准确率或多跳分数
智能体架构（15）	架构精良且可扩展为优秀	角色名事件轨迹与失败重试可检查；自主多 Agent 能力与优秀档仍需消融和效果证据
自动化程度（10）	全流程自动化 + 自愈为优秀	全链路自动化，断源退避重试、错误隔离、健康检查与指标暴露（第 7 章）

评价项（分值）	档位要求	本项目响应
文档质量（15）	详细设计图与流程图、逻辑严谨	本报告含总体架构图、Agent 编排图、问答流程图与完整设计论述

1.3 设计原则

六条原则贯穿全部设计决策，也是评审本系统时的核对基准：

- 1. 证据先于结论：来源 URL 与人工摘要可追溯；逐字段原文片段和抓取时间仍是后续完善项，来源冲突保留而不由模型武断裁决。
- 2. 事实、推断、建议分层：数据字段明确区分“来源原文”“规则归一化”“系统推断”，不把厂商未确认的信息说成事实。
- 3. 增量与时间语义正确：区分发布时间、更新时间、首次采集时间与富化完成时间，保留修订历史。
- 4. 可复现优先：断网、无 API Key、无付费模型也能完整运行核心演示；在线连接器与可选模型是增强项而非前提。
- 5. 最小依赖、可审计：Python 标准库 + SQLite/FTS5 + 原生前端，零第三方运行时依赖；多 Agent 必须有职责、契约、决策点与轨迹，而不是多个提示词名称。
- 6. 安全边界内研究：不执行 PoC、不扫描未授权资产；外部文本一律视为不可信输入。

2 系统总体架构设计

2.1 架构总览

系统采用分层架构（图 2-1）：自下而上为公开数据源层、采集与分诊层、知识存储层、富化与关联层、问答层、服务与呈现层；右侧纵向贯穿的是运行与轨迹审计，任何一步 Agent 决策都写入事件表供界面复核。

图1 知盾系统总体架构

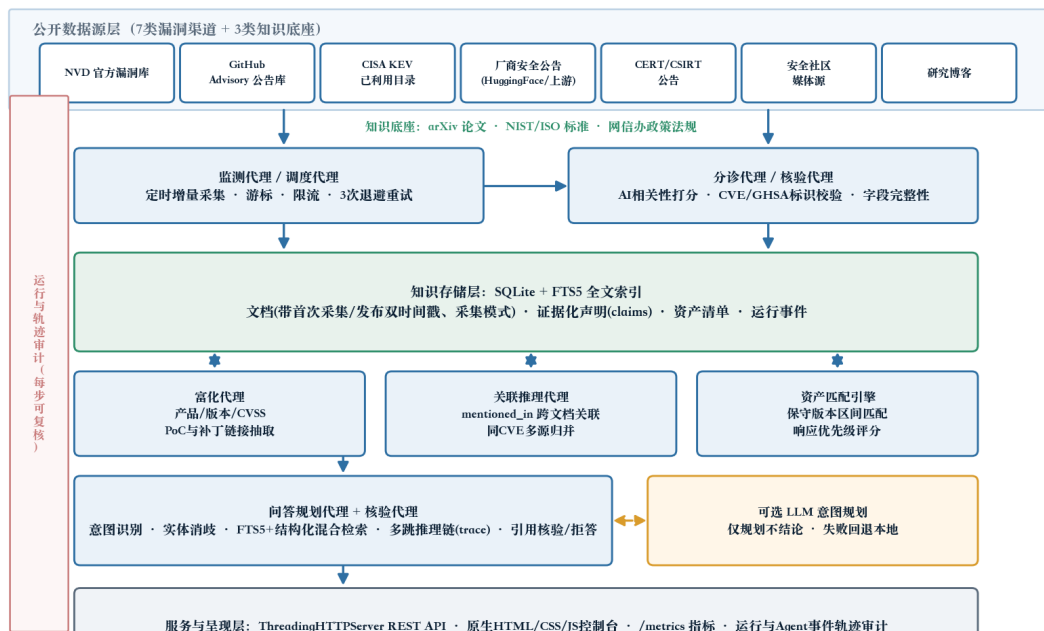


图 2-1 知盾系统总体架构

数据源层现有 12 个在线配置：9 个漏洞监测候选源与 3 个知识底座源。配置类别不是评分所需的已验证独立类别；一次联网开发运行也不能代替持续可用性和时效测试。采集与分诊层做增量拉取、AI 相关性过滤与标识校验；SQLite 保留文档和带出处声明；富化层做来源字段抽取与本地虚构资产版本匹配；问答层做检索、同 CVE 双源聚合和有限规则路径。

2.2 关键技术选型说明

表 2-1 关键技术选型与理由

决策点	选型	理由与被否备选
后端语言与框架	Python 3.10+ 标准库 ThreadingHTTPServer	竞赛原型要求可携带、可复现： 零第三方运行时依赖意味着评委 机器上 python3 一条命令即可运 行；Flask/FastAPI 被否，因其引 入依赖链且本系统无 ORM/模板 需求
存储	SQLite + FTS5 全文索引	单文件、事务安全、内置 BM25 全文检索；触发器维护索引一致 性；PostgreSQL/Elasticsearch 对 部署与演示成本过高
实体归一	CVE/GHSA 正则提取 + canonical_id 归并	漏洞情报天然以标准标识为中 心；自研嵌入聚类被否，因小样 本下规则可解释且准确
问答检索	FTS5 BM25 + 规则关系 + 可选 GLM-5.3 段落选择	离线规则可复现；向量召回和语 义泛化尚未验证
前端	原生 HTML/CSS/JS 单页控制台	无构建链、CSP 严格、演示零故 障；React/Vue 对本场景收益有 限
LLM 集成	GLM-5.3 意图规划与公开证据段 落选择；失败本地回退	模型不写库、不调工具、不生成 安全结论——把不可控性限制在 最小边界内；这是工程判断而非 能力限制
部署	直接运行 + Dockerfile/Compose + GitHub Actions CI	同一代码库覆盖裸机演示与容器 化部署两条路线

2.3 数据流水线与部署形态

一条情报的生命周期是：连接器拉取原始记录 → 分诊代理判定 AI 相关性并校验标识 → 归一化代理映射到统一模式并计算内容哈希 → 幂等写入文档表（重复内容跳过、变更内容原位更新并重建声明）→ 富化代理抽取证据化声明 → 关联推理代理建立跨文档边 → 资产匹配引擎比对本地图表清单 → 问答层按需检索聚合。全流程无人工干预，每步落盘事件轨迹。

部署上支持三种形态：裸机直接 `python3 -m app.server`（离线演示默认）；`docker compose up`（命名卷持久化、非 root 运行、健康检查）；CI 中 `unittest` 全量回归。定时调度默认 1800 秒、最短 300 秒，现场演示用 `--no-scheduler` 关闭在线请求保证确定性。

3 智能体方案设计

3.1 角色划分与职责契约

系统将情报流水线拆解为 10 类可审计角色。每个角色有明确的输入、输出契约与决策点，所有动作写入 events 表（agent/action/status/detail/occurred_at），供“运行与轨迹”页面复核。

表 3-1 Agent 角色与职责契约

角色	输入	输出与决策点	失败行为
调度代理	定时器/手动触发	选择启用源、规划批次、创建 run	单源失败不阻塞批次
监测代理	源配置+增量游标	原始记录列表；10 分钟重叠窗口容忍乱序发布	转交自愈代理重试
自愈代理	采集异常	指数退避重试（1s/2s/4s，3 次），标记源错误与健康度	3 次失败后隔离该源
分诊代理	原始记录	AI 相关性评分（阈值 0.34）、类别判定	低分记录标记 skipped
核验代理	归一记录	字段完整性、CVE/GHSA 标识合法性	非法标识拒绝入库
归一化/索引代理	校验后记录	canonical_id 归并、内容哈希幂等、FTS5 索引	更新时重建声明
富化代理	入库文档	证据化声明（产品/版本/CVSS/修复/PoC 链接）	缺字段标注“待评估”
关联推理代理	新文档+存量库	mentioned_in 跨文档边、别名边、知识关联边	无关联则不建边
问答规划代理	自然语言问题+会话状态	意图集合、检索词、实体消歧、路由到应答策略	证据不足输出拒答

角色	输入	输出与决策点	失败行为
核验代理（问答）	候选答案+引用	引用完整性、答案标记、冲突与不确定性提示	拒答并说明缺失

3.2 任务编排与自主决策

编排模型是“确定性主干 + 受控增强”：采集、归一、富化等步骤均由显式代码路由与阈值执行，事件轨迹可复核。可选 GLM-5.3 只参与问答意图规划和对本地生成、带出处的公开情报段落作选择；不会执行工具或生成新的安全事实。模型请求失败时回退本地规则。Coding Plan 端点的一条真实 HTTP 问答已走通意图规划和证据选择；长期稳定性、质量提升及广泛性能尚未验证。

图2 情报处理流水线的 Agent 编排与失败自愈

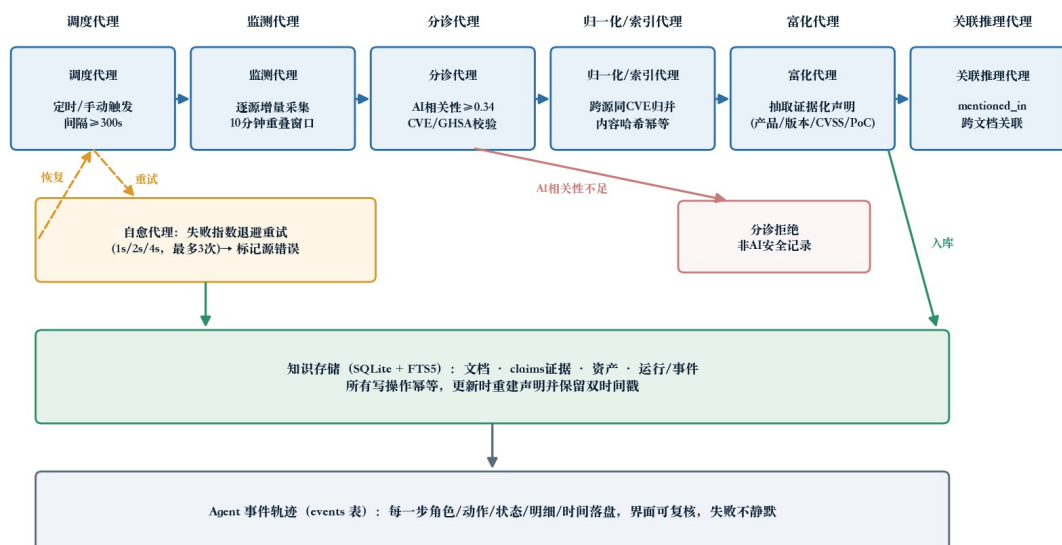


图 3-1 情报处理流水线的 Agent 编排与失败自愈

自主决策点的具体示例：分诊代理依据标题/摘要/正文/产品字段的 AI 术语命中数计算相关性分（命中产品别名加权），低于 0.34 的记录被过滤，避免通用漏洞噪声污染知识库；归一化代理发现同源同外部 ID 但内容哈希变化时，选择原位更新并

重建声明而非插入新行，保证“同一公告的修订”不产生重复实体；自愈代理对超时/限流/解析错误统一走退避重试，成功后清零失败计数，连续失败则将源标记为 error 并保留最后一次错误信息供运维排查。

3.3 安全边界：不可信输入与注入防护

在这些边界之上，系统内置了 Agent 自安全自检（app/security_selfcheck.py 与 /api/security-selfcheck）：在临时数据库注入携带提示词注入载荷、file:// 与本机回环链接的对抗样例，对照 OWASP Agentic AI 安全建议归纳的六个攻击面逐一断言——推理过程（注入指令只能作为被检索的数据，不产生服从性表述）、记忆与会话（跨会话上下文不串扰）、工具与外链（参考链接仅 https 白名单、PoC 永不执行）、身份与最小权限（未配置模型时规划器保持本地、来源正文不出域）、人工监督（证据不足必须拒答）、多智能体交互（事件留痕与重放幂等）。自检在界面“运行与轨迹”页可视化呈现，并配有单元测试作为当前开发回归样例。六项自检是团队自定义映射，不是 OWASP 官方认证，也不能覆盖所有攻击面。

外部网页、公告与 PoC README 一律按不可信数据处理，不把来源文本当作系统指令。可选 GLM-5.3 会收到用户问题及本地已生成的候选公开情报答案段落，用于意图规划与证据选择；资产段落和数据库全文不会发送。模型不能调用工具、写库或新增事实，超时和网络错误回退本地。服务侧另有 CSP、Origin/Host 写入校验、请求体 1 MB 上限、路径穿越防护与安全响应头。资产关联只处理本地授权清单，不探测陌生目标。

4 情报监测模块设计

4.1 数据源覆盖

监测按真实渠道类别核算，不能按 URL 数或配置中的 category 字段直接认定得分。当前 sources.json 有 12 个在线条目，其中 9 个属于漏洞监测候选、3 个属于论文/标准/政策知识底座；部分渠道公告会重叠：

表 4-1 数据源配置 (config/sources.json)

来源	类别	连接器	说明
NVD CVE API 2.0	官方漏洞库	nvd	关键字过滤 AI 产品与攻击面；支持 NVD_API_KEY
GitHub Advisory API	开源公告库	github_advisories	GHSA 公告，生态覆盖广；支持 GITHUB_TOKEN
OSV.dev Query API	开源公告补充	osv	针对配置中的 AI 软件包查询；与 GHSA 可有重叠
CISA KEV Feed	政府已利用目录	cisa_kev	已知被利用漏洞，可信度权重最高 (0.98)
HuggingFace Blog RSS	厂商博客候选	rss	通用博客经关键词过滤；不能直接等同漏洞公告
CISA 网络安全公告	CERT 公告	rss	CERT/CSIRT 候选源；曾遇 403，需复测
BleepingComputer RSS	安全社区媒体	rss	社区媒体渠道，低置信度 (0.65)
安全客 RSS	安全社区媒体	rss	中文 AI 安全文章候选源；需持续核验筛选效果

来源	类别	连接器	说明
NIST 网络安全洞察博客	研究博客	rss	通用研究博客，需逐篇核验漏洞相关性
arXiv cs.CR RSS	知识底座-论文	rss	AI 安全学术论文流
NIST 标准新闻 RSS	知识底座-标准	rss	技术标准动态
网信办生成式 AI 管理办法页	知识底座-政策	static_html	政策法规单页采集

上述是连接器配置，不是已成功监测的九类证据。开发期间记录过一次联网任务：12 条目中 10 条返回成功、入库 134 篇；原始批次日志尚未随仓库归档，不能独立复核，更不能证明七类持续实时监测。离线演示使用 7 条自行撰写、带原 URL 的公开来源摘要（3 个 CVE、论文、标准、政策），并非原站全文快照或实时抓取。

2026-09-29 在独立临时数据库中完成两源增量验收：CISA KEV 首次写入 6 条、原样重放跳过 6 条；OSV.dev 首读读取 287 条、写入 285 条，增量重跑无新增。又完成一次 12 条配置的全源短时运行：10 条任务成功、2 条 HTTP 403，读取 465 条、入库 442 篇；任务轨迹、来源原字段与内容哈希分别归档在 docs/evidence/ 的两份压缩 JSON。成功源中有无匹配内容的条目，另有论文、标准、政策知识底座；这不能证明 7 类独立漏洞来源持续监测或 ≤ 6 小时时效。

4.2 连接器抽象与增量机制

所有连接器实现统一契约 `fetch_source(source, since, limit)`：输入源配置与增量游标，输出统一模式记录（`external_id/title/summary/body/url/published_at/identifiers/product/versions/fixed_versions/refs` 等）。六种连接器类型（`nvd/github_advisories/osv/cisa_kev/rss/static_html`）各自封装分页、限流头与字段映射；新增一类源只需在 `sources.json` 加条目，符合开闭原则。

增量语义：游标记录上次成功时间，下次采集回看该时间并额外叠加 10 分钟重叠窗口，容忍来源乱序发布与轻微时钟偏差；正确性由入库幂等保证——重叠窗口带来的重复记录会在内容哈希对比时被跳过，不会产生重复实体。

4.3 去重与归一

去重分两层：同源幂等（`source_id + external_id` 唯一键，内容哈希相同则仅刷新 `last_seen`，变更则原位更新并重建声明）；跨源归一（从标题/摘要/正文/标识符提取 CVE/GHSA，映射到 `canonical_id`，同一 CVE 的多份来源文档形成证据组，各自保留原文措辞与置信度）。例如 CVE-2024-37032 同时来自 GitHub 公告与 Wiz 研究分析，系统将其归并为一个漏洞实体的两份证据，而非两条独立情报。

4.4 时效性度量

监测时效性（发布到采集延迟）的度量基础设施已内建：每条文档记录 `published_at`（来源发布时间）与 `first_seen`（首次采集时间）双时间戳，并标记采集模式（demo 快照 / live 在线）。`collection_latency_stats` 按模式分桶输出样本数、P50/P95/ 最大延迟，通过 `/api/dashboard` 与 Prometheus 文本 `/metrics`（`zhidun_collect_latency_hours{scope=...,stat=...}`）暴露。调度间隔可配置至最短 300 秒；离线人工摘要的发布时间多只有日期，系统按零点计算的时间差只验证统计管道；小时级赛题档位需真实线上精确时间戳和持续运行数据。

5 情报富化模块设计

5.1 证据化声明模型

富化的核心抽象是 claims 表：每条声明是一个三元组（subject, predicate, object），必须挂接来源文档（document_id 外键）、证据片段（来源摘要摘录）与置信度。置信度由来源类别基线（CISA KEV 0.98、NVD 0.96、GitHub 0.92、厂商 0.86、博客 0.62 等）经规则微调得出——例如 PoC 链接因属于间接证据，在来源基线上再降 0.08~0.12。这一设计使“富化”从黑盒模型输出变成可审计的证据抽取：当前能回答“来自哪份文档、给出了什么摘要与来源权重”；证据片段通常是文档摘要而非逐字段原文定位，置信度只是启发式来源分层，不是经校准的正确概率。OSV 数据实测发现同一公告同时给出版本区间和大量逐版本枚举，旧逻辑产生 42,838 条声明；首轮压缩至 4,829 条时发现可能遗漏区间外或无法比较的版本，故改为只跳过可证明已由数值区间覆盖的枚举版本，并补齐 9 条无终点区间，最终为 13,378 条。完整来源字段仍存于 raw_json；声明数量不是富化准确率。

5.2 字段抽取与规则扩展

表 5-1 富化维度、方法与不确定性处理

维度	抽取/推断方法	输出示例 (CVE-2024-34359)	不确定时行为
受影响产品与版本	来源字段映射 + 区间规范化	affects_product=llama-cpp-python; affected_version=">= 0.2.30" "<= 0.2.71"	无版本信息不落边
CVSS 与风险级别	数值校验 (0-10) + 级别映射	cvss=9.6; severity=Critical	标注“待评估”，不计 0 分
修复版本与补丁链接	来源 fixed 字段 + patch 标签参考	fixed_version=0.2.72; 补丁链接仅在来源有明确标签时收录	明示“证据不足，不应推测”

维度	抽取/推断方法	输出示例 (CVE-2024-34359)	不确定时行为
PoC 参考链接	URL 语义识别 (poc/exploit 关键词与标签)	poc_reference=候选公开链接 (仅元数据, 离线样例无此项)	明示“未发现已核验 PoC”
相关论文/分析关联	三级自动关联推理 (5.3 节)	本离线案例未关联论文; 有明确提及或同产品线索才建立边	区分“来源提及”与“产品重合推断”
受影响资产匹配	本地授权清单 × 版本区间保守匹配	资产“演示-虚构-llama-cpp-python 模型服务”→ affected	版本不可解析 →unknown, 不断言
处置优先级	CVSS × 暴露系数 × 关键度公式	priority=9.6 (虚构内部资产、关键度 4)	CVSS 缺失 →priority=null

5.3 自动关联推理

关联推理代理维护三类关系边，强度递减：（1）同 CVE 归并——不同来源文档因共享 canonical_id 形成证据组，回答时聚合去重并标注来源差异（如 GitHub 标 Moderate 而 Wiz 分析给出部署条件下的更大影响面，两者并列呈现而非取其一）；（2）mentioned_in 边——任何知识文档（论文/综述/政策解读）正文提及某 CVE 即建立“该文档 → 该漏洞”的反向关联，问答与详情页可据此给出“哪些研究讨论了这个漏洞”；（3）产品重合推断——文档未点名 CVE 但涉及同一产品时，标注为弱关联并明示推断理由（“文档未直接提及该漏洞标识”）。关联建立与使用时都输出关联理由，避免“相关”变成黑盒。

5.4 资产影响评估

资产匹配只面向团队登记的授权清单（名称均以“演示-虚构-”前缀明示合成数据）。版本匹配采用保守区间语义：支持 >= / <= / < / > / == 组合区间（逗号连接为

AND、多区间为 OR），自动合并“一个下界 + 一个上界拆成两条”的常见数据源写法版本无法数值化时返回 unknown 而非猜测。处置优先级公式为： $\text{priority} = \text{CVSS} \times \text{暴露系数}(\text{internet } 1.3 / \text{internal } 1.0 / \text{isolated } 0.7) \times (0.6 + \text{关键度}/10)$ ，CVSS 缺失时优先级为空并提示待评估——避免“没有评分=零风险”的误导。

```
# 资产优先级评分 (app/intelligence.py)
exposure = {"internet": 1.3, "internal": 1.0, "isolated": 0.7}[asset["exposure"]]
priority = round(cvss * exposure * (0.6 + asset["criticality"] / 10), 1) \
    if cvss is not None else None # CVSS 缺失 → 待评估而非 0
```

5.5 冲突与不确定性处理

多源分歧是常态而非异常：不同来源对同一 CVE 可能给出不同 CVSS 版本的评分或不同严重性标签。系统的处理原则是并列呈现 + 显式提醒（“不同来源评分存在差异，需按各自 CVSS 版本及更新时间复核”），绝不由模型静默裁决成单一数值；富化声明的置信度字段为后续人工裁决提供排序依据。

6 情报问答模块设计

6.1 问答执行流程

图3 证据式问答执行流程（含多轮上下文与拒答分支）

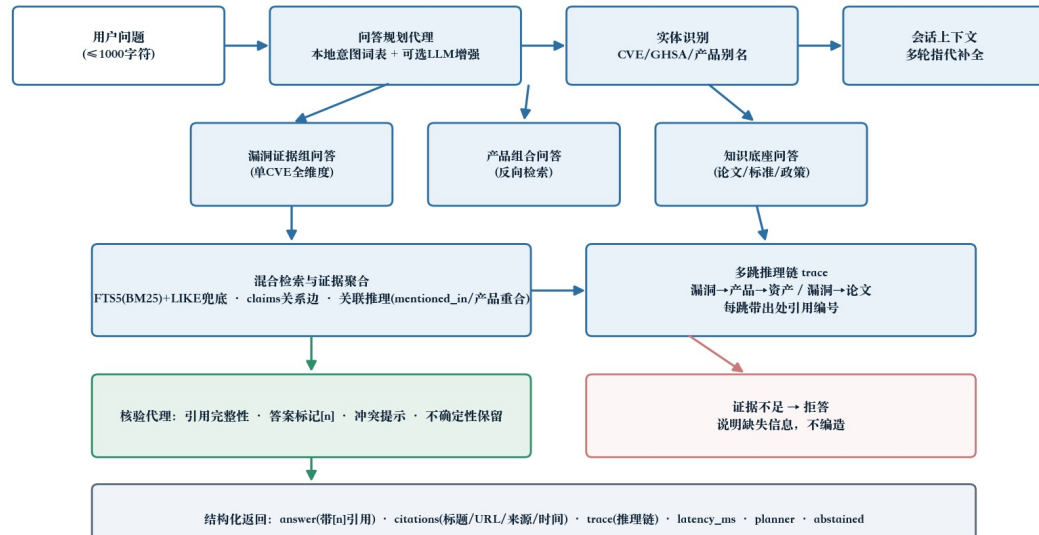


图 6-1 证据式问答执行流程

问答流水线分五步：意图规划（本地意图词表覆盖资产/修复/PoC/风险/论文/标准/政策/攻击链九类意图，可选 GLM-5.3 增强）；实体识别（CVE/GHSA 正则 + 产品别名词典 + 会话上下文补全多轮指代）；路由分发（漏洞证据组 / 产品组合 / 知识底座三条应答策略）；证据聚合（FTS5 BM25 检索 + claims 关系边遍历 + 关联推理文档注入，答案关键段落挂 [n] 引用标记）；核验输出（引用结构与 URL 检查、可选模型证据段落选择、规则关系路径 trace、延迟与规划器标记、拒答分支）。

6.2 规则关系路径与适用边界

回答的 trace 字段记录实际使用的规则关系。例如 Ollama 问题会列出 CVE → affects_product → ollama，以及按本地虚构清单作出的版本匹配；同一 CVE 下的 GitHub 公告与 Wiz 分析形成双来源证据组。每条边应注明来源或本地清单依据。当

前路径主要依靠标识归并和显式规则，三道开发双源题都围绕同一 CVE，尚不能证明对新案例的跨文档语义检索和多跳推理准确率。

6.3 多轮对话与拒答

会话状态保存最近漏洞与产品实体，支持“接着说，它的风险等级与修复版本？”这类省略主语的追问。拒答是显式设计而非异常路径：知识库中不存在该实体（如 CVE-2099-99999）时返回 `abstained=true`、空引用与缺失说明；证据不完整时（如无修复版本）答案明示“当前证据没有明确修复版本，不应推测补丁版本”。这直接对应评测中的 `safety_abstention` 题型。

6.4 可选 GLM-5.3 的作用与数据边界

项目默认适配智谱 GLM-5.3。服务和 CLI ask 启动时从项目根 ``.env.local`` 读取 `ZHIPU_API_KEY`（文件须 `chmod 600`），也支持同名环境变量；`ZHIPU_BASE_URL` 的代码默认值是标准按量端点 `https://open.bigmodel.cn/api/paas/v4`，本项目使用的 Coding Plan 密钥在 ``.env.local`` 中设为 `https://open.bigmodel.cn/api/coding/paas/v4`；`ZHIPU_MODEL` 默认为 `glm-5.3`，`GLM_TIMEOUT_SECONDS` 默认为 25。模型只规划白名单问题意图，并从本地生成的带出处公开情报段落中选择相关段落；用户问题和这些候选公开段落会送到云端，本地资产段落及数据库全文不发送。模型不调用工具、不写库、不新增事实；错误或超时自动回退，响应标注 `model/model_used/model_role/model_fallback_reason`。2026-09-29 真实标准按量端点对当前密钥返回 HTTP 429/错误码 1113；切换 Coding Plan 端点后，一条 Ollama CVE 问答完整经过本地 HTTP API，返回 `model_used=true`、`planning+evidence_selection`、两条引用及约 2.7 秒响应。这不构成整体性能与质量提升证明。密钥不得进入仓库与报告。

6.5 真实输出示例

问：CVE-2024-34359 的 CVSS、修复版本和相关研究有哪些？

答：CVE-2024-34359: llama-cpp-python 模型元数据模板注入。[1]

关联产品：llama-cpp-python。[1]

公开来源给出的风险级别：Critical; CVSS 9.6。[1]

修复版本证据：0.2.72。建议按厂商公告升级并复测。[1]

公开影响版本范围：>= 0.2.30; <= 0.2.71。[1]

当前没有可确认与该漏洞直接相关的论文、标准或政策记录。

```
citations: [ {number:1, title:"CVE-2024-34359: llama-cpp-python 模型元数据模板注入",
  url:https://github.com/abetlen/llama-cpp-python/security/advisories/GHSA-56xg-
wfcc-g829, ...} ]
```

```
trace: [ {from:"CVE-2024-34359", via:"affects_product", to:"llama-cpp-python",
evidence:"[1]"} ]
```

```
latency_ms: 3.18  planner: local  abstained: false
```

7 系统实现细节

7.1 代码结构

表 7-1 模块清单与职责

模块	实现形式	职责
app/connectors.py	Python	六类连接器：NVD/GitHub/OSV/KEV/RSS/静态页，字段映射、增量、限流
app/pipeline.py	Python	Agent 编排：分诊、入库、事件轨迹、调度器、重试自愈
app/intelligence.py	Python	归一化、AI 相关性、证据抽取、版本匹配、资产优先级、关联知识
app/qa.py	Python	意图规划、三路应答策略、多轮会话、拒答
app/db.py	Python	SQLite 模式（含在线迁移）、FTS5 触发器、幂等 upsert、延迟统计
app/server.py	Python	REST API、静态服务、CSP 与跨源防护、指标输出
web/	HTML/CSS/JS	七视图控制台：总览、漏洞、知识、问答、来源、资产、运行轨迹
tests/ + scripts/	unittest + Python	单元测试与 9 道开发规则自测脚本；题目与 fixture 同源
app/security_selfcheck.py	Python	OWASP Agentic AI 六攻击面自安全自检（临时库对抗测试）
app/llm.py / cli.py	Python	智谱 GLM-5.3 规划与证据选择客户端（兼容旧 LLM 变量） / CLI 入口

7.2 数据库模式

表 7-2 核心数据表

表	关键字段与约束
documents	source_id+external_id 唯一；canonical_id 归并键； published_at/first_seen 双时间戳；mode 标记 demo/live；content_hash 幂 等；versions/fixed/refs/identifiers JSON；FTS5 触发 器同步索引
claims	subject/predicate/object 三元组 + document_id 外键 + 证据片段 + 置信度；唯一约束防重复声明
assets	授权资产清单：产品/版本/暴露面/关键度/负责人
sources	连接器配置镜像：游标、last_attempt/ last_success、fail_count、status、last_error
runs / events	采集批次计数（fetched/inserted/updated/skipped/ errors）与 Agent 事件轨迹

7.3 HTTP API

表 7-3 REST API 一览（默认 http://127.0.0.1:8765）

方法	路径	功能
GET	/api/health · /api/dashboard	健康检查；统计+近期文档+来源 +批次+事件+延迟统计
GET	/api/documents	FTS5/LIKE 检索，kind 与 limit 过滤
GET	/api/vulnerabilities[:id]	按 CVE 归并的漏洞卡片；详情 含证据组、claims、资产匹配、 关联文档

方法	路径	功能
GET	/api/sources · /api/runs · /api/assets	来源健康度、运行与事件轨迹、资产清单
GET	/metrics	Prometheus 文本指标（文档/漏洞/声明计数 + 采集延迟分桶）
POST	/api/ask	证据式问答：answer/citations/trace/latency_ms/planner/abstained
POST	/api/collect	mode=demo 同步导入离线样例；mode=live 后台在线采集
POST	/api/assets	登记授权资产（名称唯一，重复即更新）

7.4 前端控制台

漏洞详情抽屉提供五段证据视图：情报时间线（各来源发布/更新/首次采集的垂直时间轴）、原始来源卡（逐条“核验原文”外链）、结构化事实（每条声明带来源置信度与可视化置信条）、自动关联知识（mentioned_in/产品重合关联，标注关联理由）、授权资产匹配（影响判定与处置优先级）。Agent 问答的消息内联证据引用与编号推理链；“运行与轨迹”页除批次与事件流外，展示 OWASP Agentic AI 六攻击面自安全自检结果。

原生单页控制台含七个视图：总览仪表盘（态势统计、最新情报、来源健康、Agent 时间线）、漏洞情报（检索/等级过滤/详情抽屉，详情含多来源证据、结构化声明、资产匹配与关联文档）、知识底座（四类文档检索）、Agent 问答（会话、引用展开、推理链展示）、数据源状态（配置/演示/在线三态区分）、授权资产（登记对话框）、运行与轨迹（批次计数与事件流）。界面明确区分“演示快照数据”与“在线连接器”状态，避免演示误导。

7.5 部署与工程化

Dockerfile 定义以非 root 用户运行，compose.yaml 绑定 127.0.0.1:8765、命名卷持久化数据库、/api/health 健康检查；GitHub Actions 配置了单元测试工作流（是否在远端持续运行须查看该平台记录）；/metrics 暴露的计数与延迟指标可直接接入 Prometheus 抓取。密钥（NVD_API_KEY、GITHUB_TOKEN、模型凭据）一律走环境变量，不落仓库。

8 核心代码说明

以下三段代码承载系统最核心的设计决策，全部可在仓库中对照阅读。

8.1 证据化声明抽取 (app/intelligence.py)

```
# 以下为核心逻辑简化摘录，完整行为以 app/intelligence.py 为准
def record_claims(db, document_id, record):
    """Store literal claims only. Inferred associations use a lower
    confidence."""
    canonical = record["canonical_id"]
    confidence = SOURCE_CONFIDENCE.get(record.get("source_category"), 0.65)
    claims = []
    if record.get("product"):
        claims.append((canonical, "affects_product", record["product"],
        confidence))
    if record.get("cvss") is not None:
        claims.append((canonical, "cvss", str(record["cvss"]), confidence))
    for version in record.get("fixed_versions", []):
        claims.append((canonical, "fixed_version", version, confidence))
    for ref in record.get("refs", []):
        pred = "poc_reference" if re.search(r"(?:poc|proof.of.concept|exploit)",
        ref, re.I) \
            else "reference"
        claims.append((canonical, pred, ref, max(0.4, confidence - 0.12))) # 间接证据降权
    for cve in CVE_RE.findall(" ".join([record.get("title", ""),
    record.get("summary", ""), record.get("body", "")])): # 显式提及关系
        if cve.upper() != canonical:
            claims.append((cve.upper(), "mentioned_in", record.get("url", ""),
            0.70))
    for subject, predicate, obj, score in claims:
        db.add_claim(subject, predicate, obj, document_id, evidence, score)
```

要点：富化被约束为“只抽取来源明确陈述的事实”，置信度按来源类别与证据间接性分层；正文扫描发现的跨 CVE 提及被固化为 mentioned_in 边，构成关联推理的数据基础。

8.2 保守版本匹配 (app/intelligence.py)

```
def match_version(version, ranges, fixed):
    """Conservative matcher: unknown means no assertion of impact."""
    current = _numeric_version(version)
    if current is None:
        return "unknown" # 版本不可解析 → 不断言影响
    if ranges:
        # 区间语义：逗号 AND、多区间 OR
        outcomes = [_eval_interval(item, current) for item in _normalize(ranges)]
        if any(o is True for o in outcomes): return "affected"
        if outcomes and all(o is False for o in outcomes): return "not_affected"
        return "unknown" # 表达式不可解析 → 不断言
```

```
if fixed:                                     # 只有修复版本时按“低于最小修复版”判定
    parsed = [v for v in map(_numeric_version, fixed) if v]
    return "affected" if parsed and _compare(current, min(parsed)) < 0 \
        else "not_affected"
return "unknown"
```

要点：宁可返回 unknown 也不猜测。这保证资产影响判断不会因数据源版本表达不规范而误报。

8.3 问答编排与拒答 (app/qa.py)

```
# 以下为 app/qa.py 的简化流程示意，非逐行源码
问题 → 本地意图词表与实体识别
若配置 GLM-5.3：仅发送问题作意图规划；出错则回退本地
从 SQLite 文档、claims 与规则关系生成带 [n] 的候选答案
若 GLM 规划成功：仅发送问题与候选公开情报段落作选择，资产段落本地保留
模型返回的段落编号须属于本地候选；不得生成新事实或执行工具
返回答案、citations、trace、abstained，以及
model/model_used/model_role/model_fallback_reason
```

要点：模型增强仅限意图规划和已有公开证据段落的选择，全程可回退；每次问答都有核验代理事件落盘，拒答同样是被记录与被评测的一等行为。

9 功能实现效果展示

9.1 演示数据与场景说明

离线演示数据由 7 条人工核验的公开来源摘要构成：3 个真实 CVE（Ollama CVE-2024-37032 含 GitHub 公告与 Wiz 研究双来源、llama-cpp-python CVE-2024-34359、Langflow CVE-2025-3248）、AgentDojo 论文（arXiv:2406.13352）、ISO/IEC 42001:2023 标准介绍、生成式 AI 服务管理暂行办法政策文本。资产清单 3 项，名称全部以“演示-虚构-”前缀声明为合成数据，无真实 IP/域名。每条记录保留原 URL、发布时间与核验日期。

9.2 关键能力演示路径

1. 多源归并：检索 CVE-2024-37032，详情页展示 GitHub 公告与 Wiz 研究两份证据 12 条结构化声明（含产品、版本、修复、别名、参考边）与各自置信度。
2. 资产匹配：虚构 ollama 0.1.33 节点按“< 0.1.34”区间判为潜在受影响；该 CVE 在离线公告中没有可核验 CVSS 数值，优先级显示“待评估”，实际暴露与利用性仍需人工核验。
3. 证据式问答：提问“CVE-2024-37032 的修复版本和本地受影响资产是什么？”，答案带 [1][2] 引用标记，trace 给出漏洞→产品、漏洞→资产两条边；追问“接着说，它的风险等级与修复版本？”验证多轮上下文。
4. 同 CVE 研究关联：提问“ollama 有哪些漏洞和相关研究分析？”，系统显示 CVE-2024-37032 及同组 Wiz 文章，trace 标注 same_cve_group；这不是通用多跳推理。
5. 拒答与安全边界：提问不存在的 CVE-2099-99999，返回 abstained=true 与缺失说明；离线样例没有 PoC，在线候选 PoC 链接仅保存元数据且绝不执行。

6. 自动化与失败处理：在授权网络下触发在线采集，可查看分诊、富化、索引和来源重试事件；演示时以实际批次结果为准，单源失败记录错误并继续其他来源。
7. Agent 自安全自检：在“运行与轨迹”页查看 6 项攻击面检查（注入隔离/会话隔离/工具边界/最小权限/拒答监督/多智能体审计），全部通过且证据可读；对应测试 tests/test_agent_security.py 可在 CI 回归。

9.3 Agent 轨迹示例

离线开发自测输出示例（数值以当次 scripts/evaluate.py 为准）：

首次导入：fetched=7, inserted=7, errors=0

原样重放：fetched=7, skipped=7, inserted=0

漏洞实体：3；虚构资产匹配：3/3

固定规则验收：9/9（基础 5、同 CVE 双源/关联 3、拒答 1）

必需来源引用存在率：11/11；事实同行引用标记：14/14

上述规则结果不等于问答语义准确率或官方评分。

10 性能测试结果与分析

10.1 评测方法与口径

scripts/evaluate.py 在临时 SQLite 中重放 7 条人工摘要和 3 个虚构资产，检查导入、原样重放幂等、同 CVE 归并、资产版本结果和 9 道预设问题。题目与构建数据同源；逐题只检查验收词、实体、来源 URL、事实所在行的 [n] 标记、部分 trace 路径与拒答状态。输出是开发规则通过率和引用结构指标，不是人工盲评的语义准确率；同一行有标记也不保证来源正文真正支撑断言。

10.2 测试结果

表 10-1 离线开发自测结果（2026-09-29；具体耗时以现场运行输出为准）

指标	结果	口径说明
单元测试	62/62 通过	2026-09-29 本地 Python 3.13.7 / macOS；命令 python3 -m unittest discover -s tests -q。覆盖 OSV 版本区间内、区间外和不可解析版本
全源短时运行	10/12 任务；442 篇	两条 HTTP 403；成功源中有无匹配内容和知识底座。另有 CISA/OSV 增量验收；见 docs/evidence/；不能代表七类持续覆盖
固定规则通过率	9/9（100%）	基础 5 + 同 CVE 双源/关联 3 + 拒答 1；非问答语义准确率
必需来源引用存在率	11/11（100%）	检查来源 ID 与 fixture URL 在 citations 中存在；另查 14/14 事实同行标记，不判语义支持性

指标	结果	口径说明
进程内问答耗时	p50/p95 运行时输出	仅 9 道固定题的 AnswerEngine.ask，无 HTTP/联网/LLM；不能证明决赛 ≤ 5 秒档
原样重放跳过比例	7/7 (100%)	第二次同一 fixture 全部 skipped；不代表未知在线记录去重准确率
漏洞实体归并	3 CVE / 7 文档	7 文档含 3 漏洞公告、1 研究文章、论文/标准/政策各 1
资产匹配	3/3 符合预期	2 个 affected、1 个 not_affected，均为虚构清单；不证明互联网资产定位
采集延迟统计	管道可用 (demo 7 样本)	人工摘要多只有日期，时间差只检查管道；不能推断在线采集小时档

10.3 局限与误差分析

证据边界：（1）早期 10/12 配置条目成功的观察未归档原始批次；新归档的 12 配置全源运行中 10 条任务成功、入库 442 篇，但两条 HTTP 403，成功源中又包含无匹配内容及知识底座条目。在线七类独立漏洞来源、持续成功率和小时级延迟未验证；（2）9 道题由开发者依照同一份 fixture 设计，仅覆盖基础事实、同 CVE 双来源/关联、一条追问和一条拒答；（3）富化精确率、召回率及问答语义准确率没有独立人工真值；（4）离线评测耗时只量单用户进程内规则引擎，一条 GLM HTTP 冒烟响应不能代表总体 p95。下一步须分离开发集与留出集，持续保存每源原始运行记录。

11 创新点总结

1. 证据化声明模型：把“情报富化”从黑盒生成重构为带出处、带证据片段、带置信度分层的 claims 三元组，多源分歧并列呈现——为 AI 安全场域高误报环境设计的可信富化范式。
2. 三级自动关联推理：同 CVE 归并、mentioned_in 显式提及边、产品重合推断（弱关联并标注理由），关联既可用于检索增强也在答案中展示推理路径。
3. 拒答作为一等能力：证据不足时显式 abstained 并说明缺什么，与引用核验一起被纳入评测题集，直接对抗情报系统的幻觉风险。
4. 受控 GLM-5.3 增强：只规划问题意图并从本地候选公开证据段落中选择，失败回退；Coding Plan 端点的一条真实 HTTP 问答已走通，质量提升仍需独立评测。
5. 全链路可审计编排：10 类 Agent 角色的每步决策落盘事件轨迹并界面可视化，失败自愈回路（退避重试+错误隔离+健康度）同样留痕。
6. Agentic AI 自安全自检：对照 OWASP 攻击面的对抗样例测试内置为产品功能——情报系统的自身安全成为可演示、可回归的展示点，与赛题主题形成闭环。
7. 指标口径分离：文档标记演示摘要与在线任务，开发题仅报告规则通过率；真实时效、富化精确率和问答准确率留待独立评测。

方案比较以功能组成和可复现条件为边界：本原型把公开漏洞来源、人工整理的知识摘要、本地资产版本匹配和带出处问答接在一套可离线运行的系统中。其他产品的具体能力需逐项实测，不能概称其缺少富化、证据链或 AI 安全覆盖。

12 限制与后续工作

当前版本的全部能力边界已在正文相应章节如实标注，此处汇总为可执行的后续计划：

表 12-1 后续工作路线

事项	计划	对应评分缺口
在线持续运行	归档在线原始批次与环境，逐类验证持续成功率，并测量带精确发布时间的 ≤ 6 小时延迟分布	监测时效性优秀档证据
富化真值评测	构建分维度人工标注集（TP/FP/FN），双人复核，报告准确率与召回率	富化准确率 $\geq 95\%$ 证据
语义检索增强	引入本地嵌入模型做向量召回，与 FTS5 混合排序；扩充题集至 50+ 并分离开发/留出集	问答泛化与多跳准确率
GLM-5.3 增强对比	在独立留出题集上对照开启/关闭 GLM-5.3 的质量、延迟和发送数据范围；扩展当前单条 HTTP 冒烟验收	智能体运用水平
生产化运维	接入告警通道、备份恢复演练、反向代理与鉴权	工程化完整 DevOps
交付材料	按初赛要求完成操作演示视频与讲解 PPT 终稿（技术报告即本文档）	提交清单

结语：本系统以“证据先于结论”为设计准则，在监测、富化与问答三个模块上形成了可运行、可测试的离线闭环。仓库内的开发规则自测可复现；一次联网观察尚缺原始日志，优秀档指标仍待独立评测。后续应先补齐持续在线运行记录和人工真值集，再讨论奖项级结论。